

Auteurs : Touhami KASBAOUI, SOC Manager · Toufik AIRANE, Cybersecurity Manager · Mouad ILMI, SOC Architect

Public et prérequis

Étudiants, débutants, personnes en reconversion et futurs analystes SOC. Savoir utiliser un navigateur et des fichiers ; aucune expérience préalable de Wazuh n'est requise pour les bases.

Objectifs

Comprendre les risques cyber, justifier des protections, analyser une alerte et préparer une escalade. Décrire une architecture SOC et vérifier la chaîne de traitement des événements dans Wazuh.

Jour 1 · Fondements de la cybersécurité

1. **Pourquoi la cybersécurité est importante** : valeur de l'information, impacts financiers et opérationnels ; dépendances entre personnes, processus et technologies ; continuité des activités.
2. **Sécurité de l'information et vie privée** : confidentialité, intégrité, disponibilité et traçabilité ; identité, droits d'accès, MFA, moindre privilège et minimisation des données.
3. **Vulnérabilités et faiblesses** : bugs, mauvaises configurations, exploitation et correctifs ; rôles de CWE, CVE, CPE et NVD ; lecture de CVSS, EPSS et KEV ; inventaire des composants avec une SBOM.
4. **Gestion du risque cyber** : menace, exposition, probabilité et impact ; priorisation selon le contexte métier ; prévention, détection, sauvegarde et reprise ; choix des traitements et risque résiduel.
5. **Acteurs de menace et réglementation** : script kiddies, attaquants opportunistes, criminels organisés, APT et menace interne ; capacités, motivations, responsabilités et protection des données selon le cadre applicable.
6. **Comportement rationnel** : vérifier une demande par un canal fiable, distinguer faits et hypothèses, reconnaître les biais, rechercher une explication alternative, signaler et agir dans son périmètre.

Jour 2 · SOC Analyst : quotidien et investigation

1. **Mission du SOC** : rôles L1/L2/L3, prise de poste, triage, qualification, priorisation, escalade et relève ; distinguer événement, alerte et incident.
2. **Preuves et référentiels** : journaux systèmes, réseau et messagerie ; Wazuh et Sysmon ; MITRE ATT&CK, Cyber Kill Chain et pyramide de la douleur pour structurer l'analyse.
3. **Investigations guidées** : force brute SSH, phishing avec pièce jointe et réponse à un ransomware sur table ; différencier tentative, accès réussi, exécution et impact confirmé.
4. **Analyse des comportements** : reconnaître les indices de persistance, mouvement latéral, commande et contrôle ou accès aux identifiants ; confronter chaque indice au contexte et aux autorisations.
5. **Malwares et enrichissement** : familles de logiciels malveillants, principes d'analyse statique et dynamique sur rapports fournis ; indicateurs de compromission, réputation et limites des outils.
6. **Analyse et restitution** : chronologie, corrélation, périmètre et niveau de confiance ; faits, hypothèses et inconnues ; compte rendu exploitable et proposition d'actions autorisées.

Jour 3 · Architecture SOC et ingénierie Wazuh

1. **Composants et flux** : agents, manager, collecte, indexer et dashboard ; parcours d'un événement jusqu'à l'alerte ; capacité, rétention et responsabilités.
2. **Accès et confiance** : identités, certificats, secrets, rôles et droits limités ; enrôlement, groupes d'agents et vérification de la configuration réellement appliquée.
3. **Collecte et détection** : sources de journaux, normalisation, décodeurs et règles ; tests positifs et négatifs avec wazuh-logtest ; diagnostic d'une alerte absente.
4. **Fonctions de sécurité** : surveillance d'intégrité des fichiers (FIM), inventaire et détection des vulnérabilités ; périmètre, autorisations et garde-fous de l'Active Response.
5. **Exploitation et résilience** : santé des composants, stockage et fraîcheur des données ; sauvegarde, mises à jour, restauration et vérification de bout en bout sur preuves.
6. **Repères d'infrastructure et d'automatisation** : rôle d'OpenStack, Terraform, Docker Swarm, Ansible et GitLab CI ; revue des changements, protection des secrets et retour arrière.

Pédagogie : explications, exemples professionnels fictifs, infographies et exercices corrigés.

Cadre : aucune intervention en production ni exécution de malware. Pratique technique uniquement sur environnement isolé, autorisé et préparé ; à défaut, analyse sur dossier. Cette formation ne constitue pas une certification éditeur.